



2 DE SEPTIEMBRE DE 2026

Análisis y Planificación del Pentest

ESECENARIO: AURORA MARKET

LOURDES MENDIETA
HACKER WOMEN COUNCIL • ETHICAL HACKING
Asunción, Paraguay

Contenido

1. OBJETIVO DEL PENTEST.....	2
2. ALCANCE.....	2
➤ SÍ SE EVALUARÁ:.....	2
➤ FUERA DEL ALCANCE:.....	2
3. AUTORIZACIÓN Y CONDICIONES.....	2
➤ PERMISOS REQUERIDOS:.....	2
➤ CONDICIONES ACORDADAS:.....	2
4. TIPO DE PENTEST.....	3
5. PLANIFICACIÓN.....	3
6. FASES DEL PENTEST.....	3
7. INVESTIGACIÓN.....	4

1. OBJETIVO DEL PENTEST

El objetivo principal de realizar este *pentest* a Aurora Market no es simplemente encontrar fallas técnicas, sino proporcionar a la organización una visibilidad clara y accionable sobre los riesgos reales a los que está expuesta su plataforma de comercio electrónico. Al tratarse de un e-commerce, Aurora Market maneja datos sensibles (información personal, historiales de compra y potencialmente datos financieros). El propósito de esta evaluación es simular el comportamiento de un atacante del mundo real para identificar vulnerabilidades en la aplicación web, la base de datos subyacente y los mecanismos de autenticación antes de que actores malintencionados puedan explotarlas. Se busca responder preguntas clave para la organización: ¿Puede un cliente manipular precios? ¿Puede un usuario de bajo nivel acceder a los datos de otros usuarios o escalar privilegios para administrar la tienda? ¿Qué información técnica está expuesta al exterior? Con esta evaluación, el equipo de desarrollo recibirá un reporte detallado que les permitirá priorizar las correcciones (parches), fortalecer la arquitectura de la plataforma y garantizar la confianza y seguridad de sus clientes.

2. ALCANCE

➤ SÍ SE EVALUARÁ:

- La aplicación web principal de Aurora Market (frontend y backend expuesto).
- La base de datos vinculada a la aplicación (evaluación de inyecciones, no acceso directo).
- Los mecanismos de autenticación y la segregación de privilegios entre los diferentes tipos de usuarios (ej. comprador vs. administrador).

➤ FUERA DEL ALCANCE:

- Ataques de Denegación de Servicio (DoS/DDoS) que puedan afectar la disponibilidad.
- Ingeniería social contra empleados o clientes de Aurora Market.
- Infraestructura física, redes internas no expuestas y servicios de terceros.

3. AUTORIZACIÓN Y CONDICIONES

➤ PERMISOS REQUERIDOS:

- Firma de las Reglas de Compromiso (RoE) y un Acuerdo de Confidencialidad (NDA). Es imperativo contar con autorización escrita y explícita de la directiva de Aurora Market antes de enviar el primer paquete de datos.

➤ CONDICIONES ACORDADAS:

- Las pruebas ofensivas no deben comprometer la integridad de los datos reales de los clientes ni interrumpir las transacciones del e-commerce.
- Cualquier vulnerabilidad crítica (ej. Remote Code Execution) que ponga en riesgo inminente el servidor debe ser reportada inmediatamente sin necesidad de esperar al informe final.

- Todo vector de ataque debe detenerse antes de causar daño colateral y reportarse de inmediato si es crítico.

4. TIPO DE PENTEST

- **Selección:** Caja Gris (Gray-Box).
- **Justificación:** Aurora Market no entrega toda la información técnica (código fuente, diagramas de red), lo cual es propio de Caja Negra. Sin embargo, para cumplir con el requerimiento de evaluar los "mecanismos de autenticación y diferentes tipos de usuarios", el equipo auditor requiere credenciales de prueba válidas (ej. una cuenta de comprador estándar y una cuenta de administrador). Este nivel de acceso parcial ubica el ejercicio como Caja Gris, permitiendo simular tanto amenazas externas (sin autenticación) como amenazas internas o clientes malintencionados (con autenticación).

5. PLANIFICACIÓN

- **Recopilación de información:** EPara mapear la superficie de ataque, se utilizarán tanto fuentes abiertas (OSINT) como interacción directa controlada con el objetivo.
- **OSINT (Fuentes Abiertas):** Se utilizarán motores de búsqueda, Wayback Machine y Shodan para buscar subdominios olvidados, paneles de administración expuestos o información técnica filtrada sobre Aurora Market en internet.
- **Fuentes Internas / Interacción:** Se interactuará con la plataforma para recopilar banners, cabeceras HTTP y examinar el código fuente del lado del cliente (HTML/JS) para identificar qué tecnologías y frameworks está utilizando la empresa.

Herramientas a utilizar y su propósito:

- **Nmap:** Se utilizará en la fase de reconocimiento activo. El propósito no es solo descubrir qué puertos están abiertos (ej. 80, 443, 3306), sino utilizar scripts de enumeración (NSE) para identificar las versiones exactas de los servicios corriendo en esos puertos y así buscar vulnerabilidades públicas (CVEs) asociadas a esas versiones.
- **OWASP ZAP (o Burp Suite):** Será la herramienta principal para el análisis web. Su propósito será interceptar, inspeccionar y modificar el tráfico HTTP entre nuestro navegador y Aurora Market. Esto nos permitirá manipular parámetros, probar inyecciones SQL en los campos de entrada, forzar el control de acceso y descubrir directorios ocultos (fuzzing).
- **Horarios propuestos:** Se propone realizar el pentest en horario de madrugada (ej. de 01:00 am a 05:00 am, zona horaria del servidor). Justificación: Dado que Aurora Market solicita explícitamente "no afectar la operación ni los datos de los clientes", ejecutar las pruebas, especialmente los escaneos automatizados o la interceptación de tráfico, durante los horarios de menor tráfico (ventana de mantenimiento) minimiza el riesgo de que la latencia generada por las herramientas afecte las compras de los usuarios legítimos.

6. FASES DEL PENTEST APLICADAS AL ESCENARIO

1. **Reconocimiento:** En esta etapa inicial, se utilizará Nmap para escanear los servidores de Aurora Market y descubrir qué puertos y servicios están expuestos. Simultáneamente, mediante herramientas OSINT y navegación manual, se mapeará toda la estructura del sitio web (URLs, formularios de login, carrito de compras) buscando identificar qué motor de base de datos o lenguaje de programación (ej. PHP, Node.js) utilizan. Espero obtener un mapa completo de la superficie de ataque y los puntos de entrada (inputs) de la aplicación web.
2. **Análisis de vulnerabilidades:** Con la información previa, se utilizará OWASP ZAP para realizar un escaneo automatizado y manual sobre los formularios de la tienda. Se buscará identificar si los campos de entrada sanitizan correctamente los datos. El objetivo es encontrar indicios de inyecciones SQL (SQLi), Cross-Site Scripting (XSS) y fallas en la lógica de negocio (ej. agregar artículos al carrito con precios negativos). Los resultados obtenidos aquí servirán como guía para la siguiente fase.
3. **Explotación:** Basado en los hallazgos anteriores, se intentará explotar activamente las vulnerabilidades encontradas de forma manual. Por ejemplo, si se identificó una posible inyección SQL en la barra de búsqueda de productos, se enviarán payloads específicos (ej. usando SQLmap o manual con Burp Suite) para intentar extraer información de la base de datos, demostrando al cliente que la falla es real y explotable.
4. **Post-explotación:** En esta fase, se evaluará el impacto del compromiso. Si en la fase anterior se logró comprometer la cuenta de un usuario estándar, el objetivo aquí será intentar un escalamiento de privilegios (Horizontal o Vertical). Se buscará acceder al panel de administración o modificar datos de otros clientes para demostrar qué tan lejos podría llegar un atacante si logra entrar a la plataforma.
5. **Informe:** Finalmente, se consolidará toda la información en un reporte técnico y ejecutivo. Se explicará detalladamente al equipo de desarrollo de Aurora Market cómo se logró cada vulneración (paso a paso), el riesgo real asociado y las remediaciones específicas de código o configuración que deben aplicar.

7. INVESTIGACIÓN

- **Metodología elegida:** PTES (Penetration Testing Execution Standard).
- **¿Por qué sería útil para este proyecto?:** PTES proporciona un marco de trabajo altamente estructurado que cubre desde las interacciones iniciales con el cliente hasta la entrega del informe. Para Aurora Market, que tiene como requisito principal que la información entregada sea "clara, útil y cuidadosamente documentada", la fase de "Reporte" de PTES garantiza que los hallazgos se clasifiquen según su riesgo real para el negocio y ofrezcan soluciones técnicas precisas para su equipo de desarrollo. Además, su fase de "Modelado de Amenazas" es ideal para abordar el requerimiento de probar los "diferentes tipos de usuarios" y sus flujos de datos.